Báo cáo Tuần 4

I. Worklog

Thời gian thực hiện: 26/10/2026 – 1/11/2026

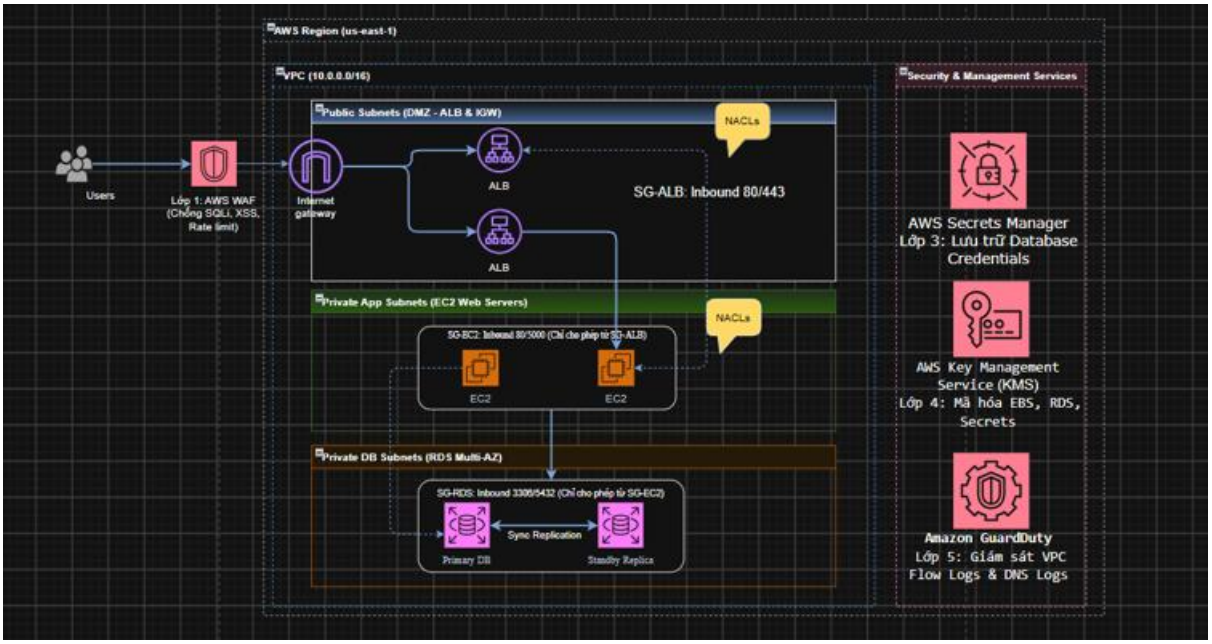
Nguyễn Xuân Nhật (MSSV: 24110293) Thời gian: 8h

- Viết kịch bản kiểm thử cho toàn bộ dự án (2 giờ)
- Tối ưu hóa chi phí và dọn dẹp tài nguyên tránh phát sinh chi phí ngầm (3 giờ)
- Viết báo cáo về dự án (3 giờ)

Nguyễn Công Bình (MSSV: 24110168) Thời gian: 8h

- Quay và chỉnh sửa video demo toàn bộ dự án theo kịch bản (4 giờ)
- Chuẩn hóa mã nguồn, hợp nhất các file CloudFormation (2 giờ)
- Cập nhật toàn bộ GitHub của nhóm và tổng kết WORKLOG 4 tuần (2 giờ)

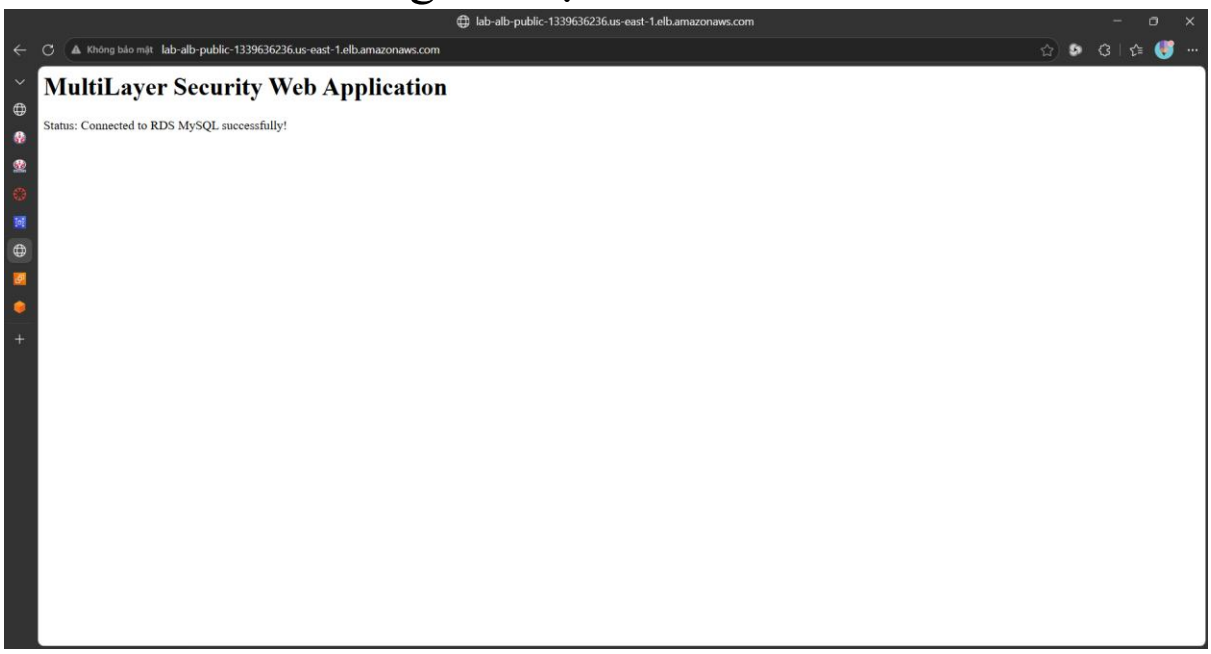
II. Sơ đồ kiến trúc dự án



Hình 1.1: *Sơ đồ kiến trúc tổng thể*

- Đây là sơ đồ kiến trúc nhóm em đã lên kế hoạch cho dự án từ tuần đầu tiên.
- Dự án được bảo mật qua 5 lớp phòng thủ dựa theo mô hình đe dọa STRIDE được phát triển bởi Microsoft: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.

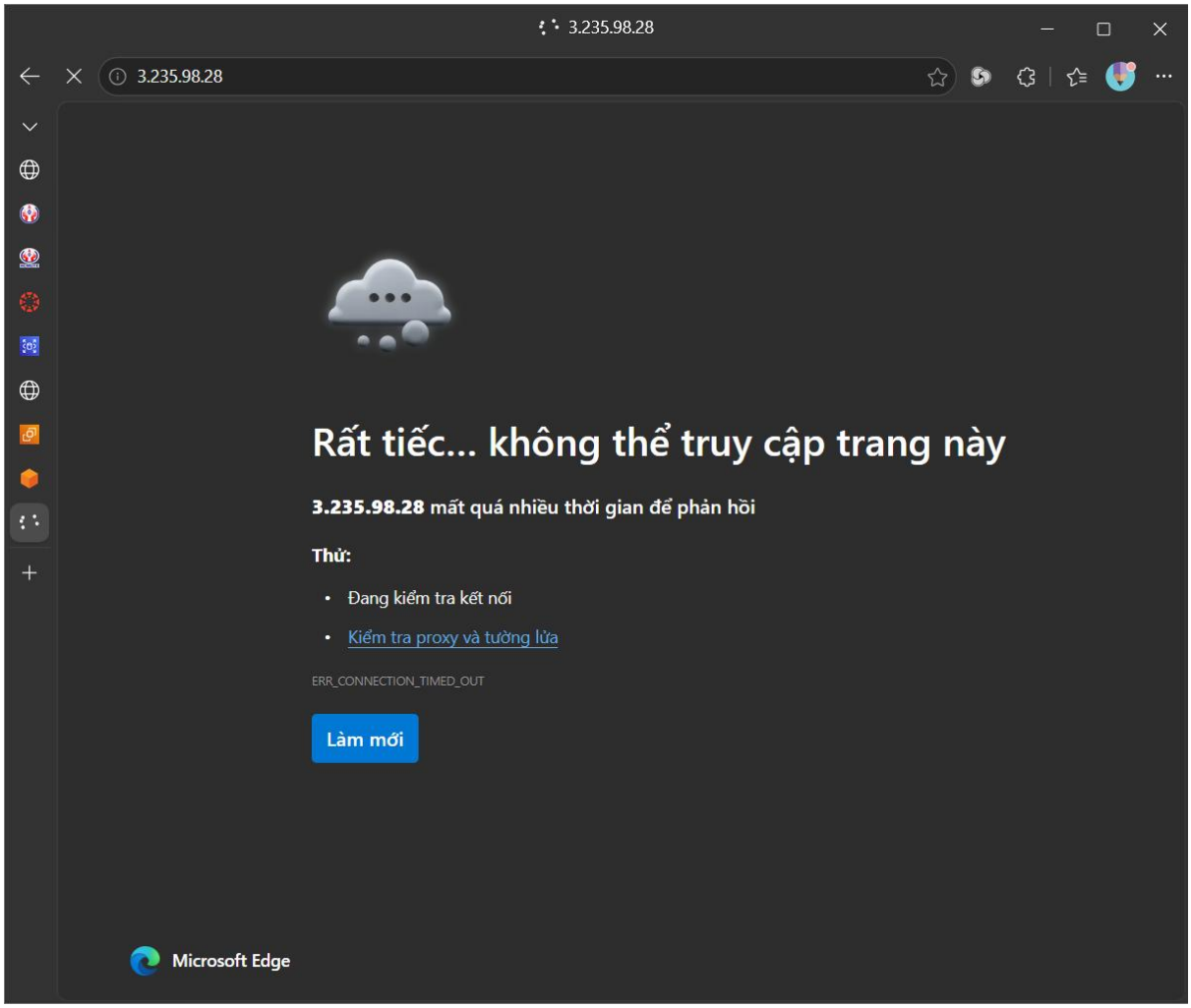
III. Kiểm thử tổng thể dự án



Hình 2.1: *Ứng dụng web truy xuất thành công cơ sở dữ liệu RDS*

Nhận xét:

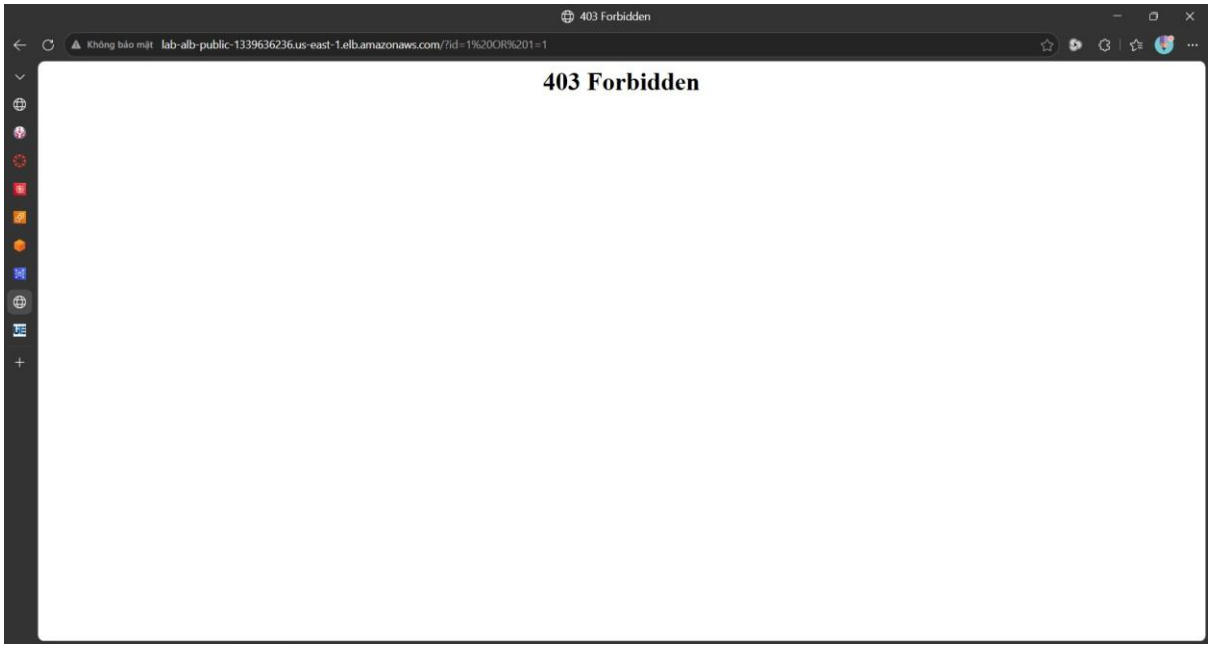
- Khi người dùng thực hiện kết nối tới trang web thông qua đường link http://Lab-ALB-Public-1339636236.us-east-1.elb.amazonaws.com sẽ truy cập vào trang web thành công.
- Nhờ cơ chế của IAM Role và Secrets Manager giúp ứng dụng kết nối tới RDS MySQL an toàn tuyệt đối mà không cần lưu trữ mật khẩu tĩnh trong mã nguồn.



***Hình 2.2**: Security Group chặn truy cập trực tiếp vào máy chủ EC2 qua IP.*

Nhận xét:

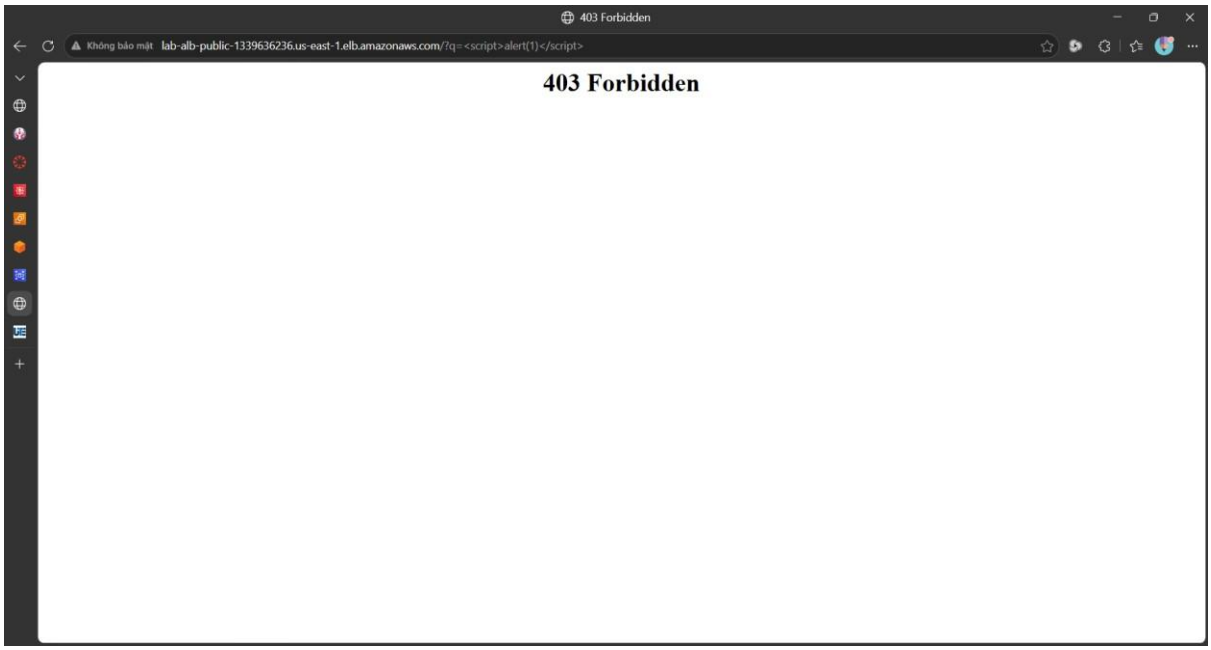
Khi gõ thử public IP của EC2 lên trình duyệt thì trang web sẽ bị treo và báo lỗi kết nối chứng minh rằng Security Group đã khóa chặt, kẻ gian không thể đi đường tắt.



***Hình 2.3**: Phản hồi HTTP 403 Forbidden khi kẻ gian tấn công SQL Injection*

Nhận xét:

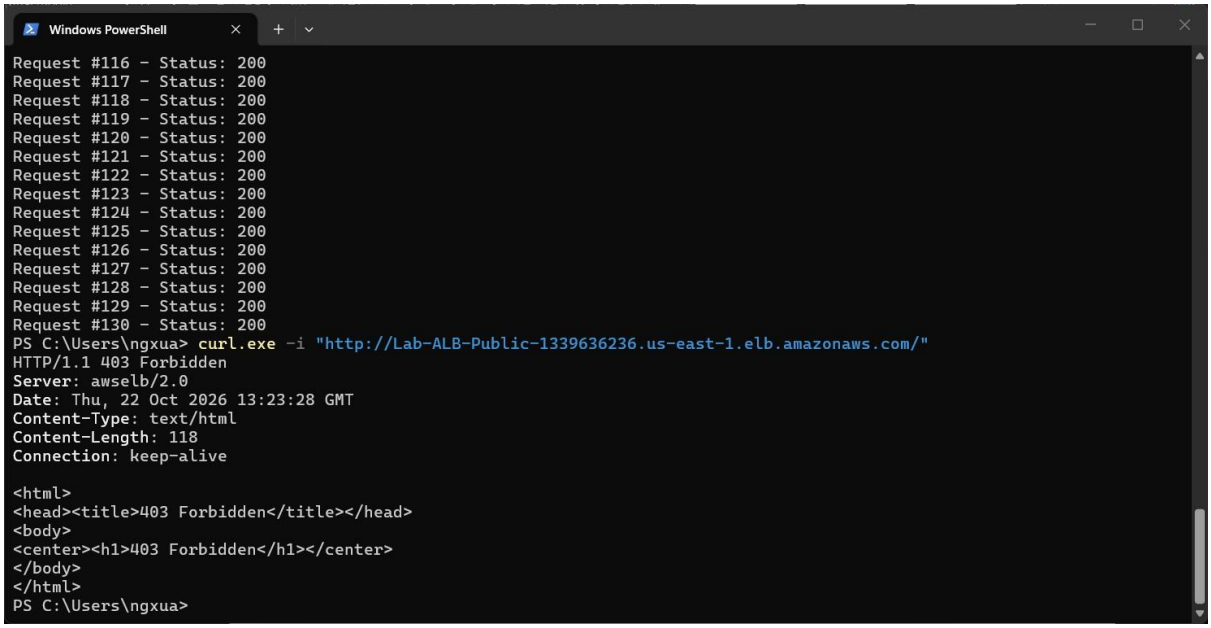
Sau khi thêm vào ?id=1%20OR%201=1 phía sau đuôi của đường link nhằm đánh cắp thông tin bằng SQL Injection. Bộ lọc WAF SQLiRuleSet đã phát hiện và chặn đứng yêu cầu ngay lập tức.



***Hình 2.4**: Phản hồi HTTP 403 Forbidden ngăn chặn tấn công Cross-Site Scripting (XSS)*

Nhận xét:

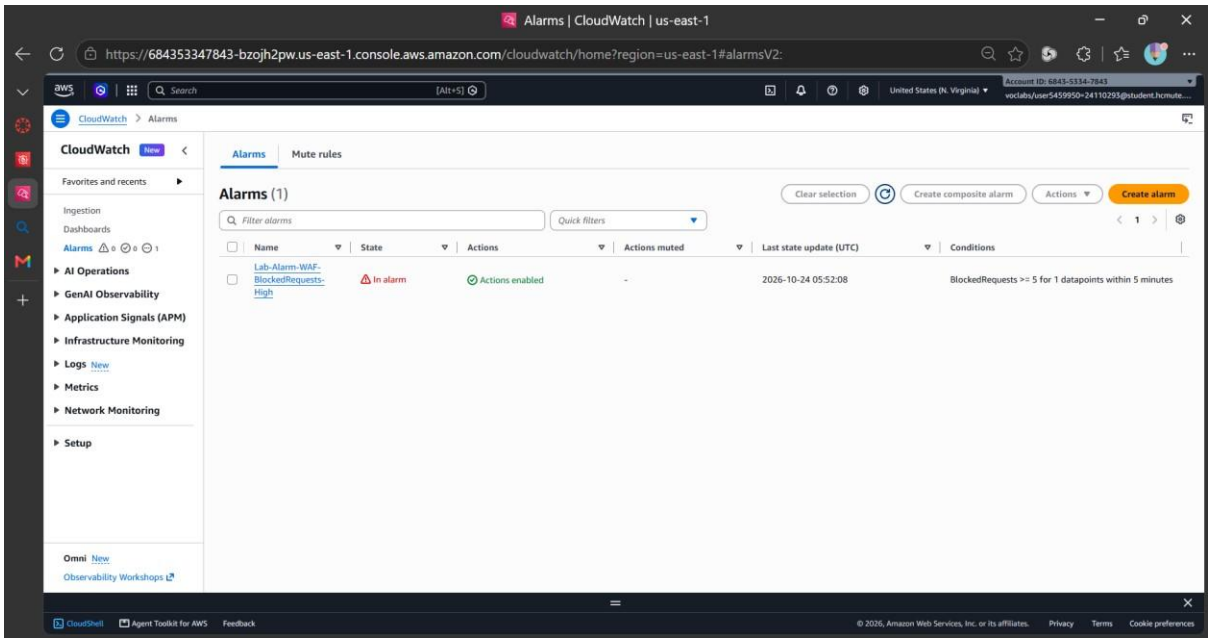
Khi dán đường dẫn có đoạn mã JavaScript http://lab-alb-public-1339636236.us-east-1.elb.amazonaws.com/?q=<script>alert(1)</script> liền bị WAF chặn lại.



***Hình 2.5**: Gửi dồn dập 130 requests làm cạn kiệt tài nguyên*

Nhận xét:

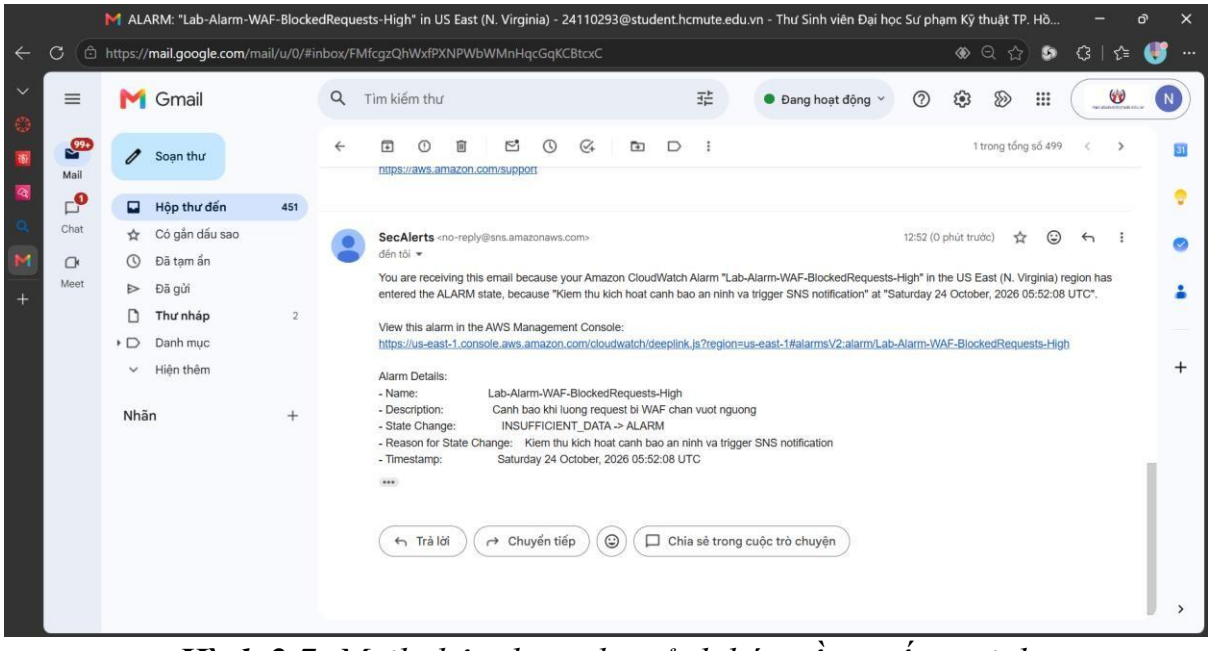
Sau khi chạy lệnh trên PowerShell nhằm gửi dồn dập 130 requests hệ thống tự động khóa IP và trả về mã lỗi 403 nhờ quy tắc RateLimit-100.



***Hình 2.6**: Amazon CloudWatch Alarm kích hoạt báo động*

Nhận xét:

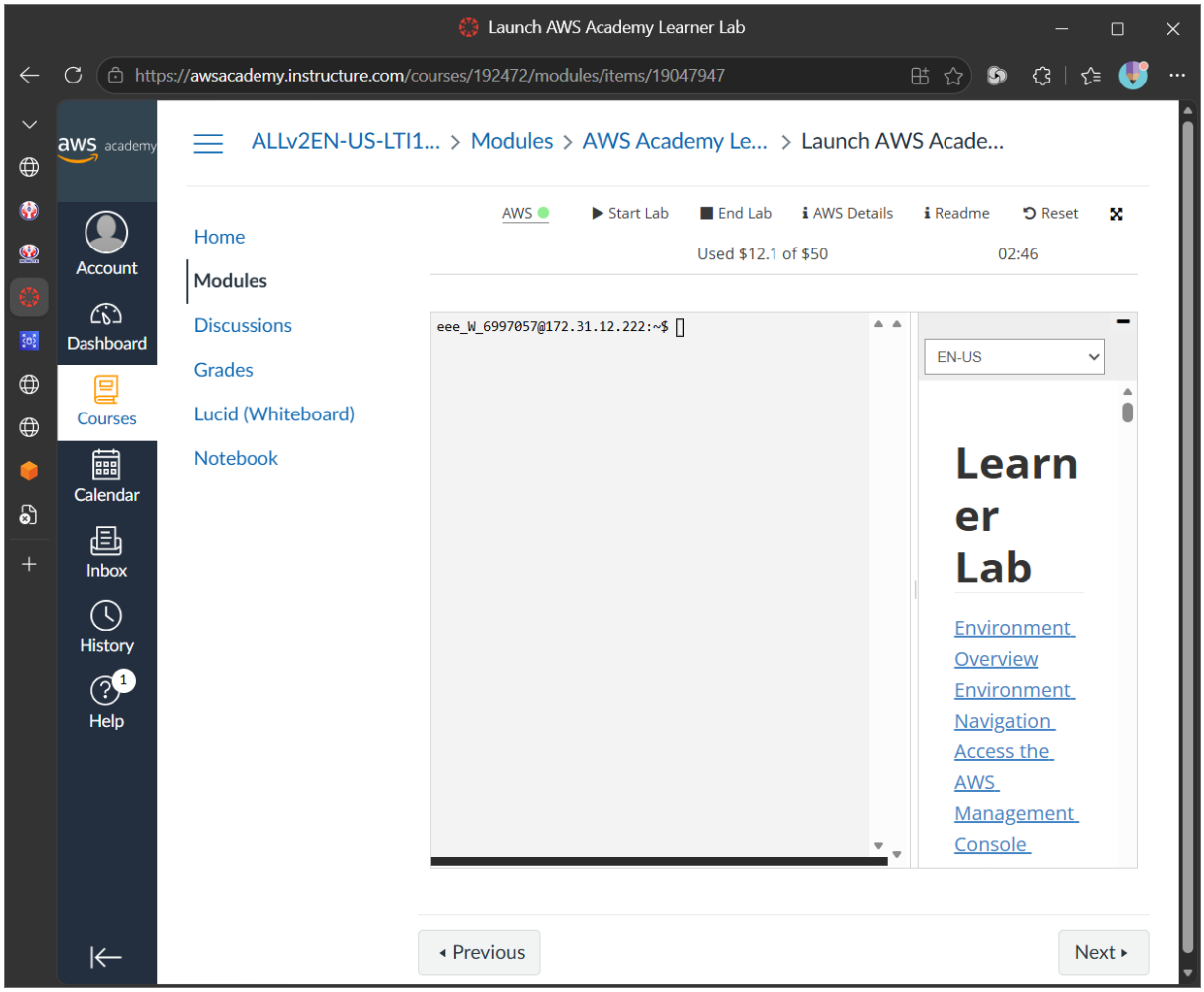
Sau khi hệ thống WAF ghi nhận lưu lượng tấn công vượt ngưỡng quy định, CloudWatch Alarm tự động chuyển trạng thái In alarm và gửi tín hiệu tới Lab-Security-Alerts-Topic được cài đặt mail của sinh viên.



***Hình 2.7**: Mail nhận được thư cảnh báo về sự cố an ninh*

IV. Đánh giá chi phí và dọn dẹp tài nguyên

Chi phí



Hình 3.1: *Giao diện lab trên trang chủ đã sử dụng 12.1$ trên tổng 50$*

Nhận xét:

- Số dư chi phí được hiển thị thông qua hệ thống phòng lab Vocareum.
- Nhóm đã kiểm soát tốt chi phí suốt 4 tuần học, số tiền dùng thử nghiệm hệ thống vẫn nằm trong hạn mức 50$.

Dọn dẹp tài nguyên

Giai đoạn 1: WAF, CloudWatch, SNS, GuardDuty

- Gỡ bỏ WAF ra khỏi Load Balancer
- Xóa các Alarm và SNS để hệ thống không gửi mail báo động nữa

Giai đoạn 2: ALB, Target Group

- Xóa Lab-ALB-Public
- Khi ALB đã được xóa thì mới xóa được Target Group

Giai đoạn 3: EC2 Web Server

- Xóa máy ảo EC2 thì ổ cứng (EBS Volume) đi kèm cũng tự mất theo.
- Kết nối từ web xuống database bị ngắt hoàn toàn

Giai đoạn 4: RDS Database

- Khi không còn máy ảo truy cập nữa thì xóa Database
- Không chọn “Create final snapshot” và “Retain automated backups”

Giai đoạn 5: Security Groups

- Xóa toàn bộ các dòng trong Inbound Rules
- Xóa các Security Groups theo thứ tự

Giai đoạn 6: Dọn dẹp nền tảng

- Xóa DB Subnet Group
- Dọn dẹp S3 Bucket
- Xóa Lab-VPC

V. Link GitHub và Video Demo

Link github: https://github.com/CongBinh-designer/Bao-mat-da-lop-cho-ungdung

Link video: https://youtu.be/RNFod-LNGfU